PLAN DE IMPLEMENTACIÓN

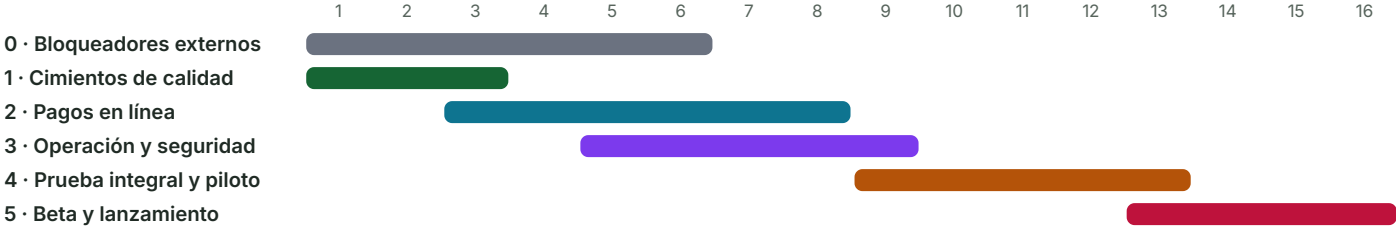
De «funciona y es seguro» a «listo para producción»

Qué falta, en qué orden, quién lo hace y cómo sabremos que está terminado. Está organizado para cumplir los criterios de la guía de arquitectura y calidad de código del proyecto (secciones 1 a 21).

Punto de partida (verificado): 227 pruebas de interfaz y 173 verificaciones de base de datos pasan; lint y compilación sin errores; 0 alertas altas en dependencias de producción; las 8 migraciones aplicadas en el Supabase real; CI en cada pull request. **No verificado todavía:** recorrido completo con cuentas reales, pagos en línea, copias de seguridad y restauración, monitoreo, revisión legal y rendimiento medido.

1. Hoja de ruta (estimación)

Supuestos: una persona de desarrollo con apoyo de Claude, jornadas normales; los plazos de abogado, proveedor de pagos y trámites son de calendario y se solapan con el desarrollo. Son estimaciones para planear, no compromisos.



Semanas desde el inicio. Un **piloto cerrado en efectivo** (3 a 5 negocios conocidos) puede arrancar ya en la semana 2, apenas se resuelvan los datos jurídicos y el plan de pago de Supabase; no espera a los pagos.

2. Fases, entregables y criterios de aceptación

Fase 0 · Bloqueadores externos (en paralelo)

Responsable: propietario · semanas 1 a 6

- **Persona jurídica:** razón social, NIT, dirección, teléfono y correo cargados como variables `VITE_LEGAL_*` en el hosting.
- **Abogado:** revisión de Términos, Política de privacidad, declaración del domiciliario, consentimiento de la fotografía y esquema de independencia frente a la Ley 2466 y el Decreto 0991; entregar las versiones firmadas y actualizar `LEGAL_VERSION`.
- **Supabase de pago** (copias de seguridad, sin pausa por inactividad), **dominio propio** y **correo de envío propio** (SMTP) para confirmaciones y recuperación de contraseña.
- **Elegir pasarela** (Bold o Wompi) y abrir la cuenta comercial; **contador** para facturación, retenciones y RNBD ante la SIC.

Criterio de salida: los textos legales ya no dicen «pendiente», existe cuenta de pasarela en modo de pruebas, y el proyecto de Supabase no se pausa.

Fase 1 · Cimientos de calidad

Responsable: desarrollo · semanas 1 a 3

- **Entorno de pruebas (staging):** segundo proyecto de Supabase y despliegue de vista previa en Vercel con sus propias variables; nunca probar contra producción.
- **Migraciones:** exportar el esquema real como migración base, adoptar la CLI de Supabase y una tabla de migraciones aplicadas; reemplazar los 38 parches sueltos de `database_updates/`. Cada migración nueva con su reversa documentada.
- **CI completo:** agregar al flujo las pruebas de base de datos (`tools/db-test` con un PostgreSQL de servicio), búsqueda de secretos, `npm audit` bloqueante para alertas altas y umbral de cobertura; proteger la rama `main` (exigir CI verde y revisión).
- **Pruebas que faltan:** servicios de clientes, negocios, administración, autenticación y los de cada nicho; pruebas de caracterización *antes* de refactorizar.
- **Refactor dirigido** de los archivos que mezclan responsabilidades: `storeService` (790 líneas), `deliveryService` (573), `useStoreDashboard` (528) y `CheckoutPage` (515), divididos por dominio sin cambiar el comportamiento.
- **Convenciones:** `CONTRIBUTING.md` (idioma de identificadores, estructura, manejo de errores común), plantilla de pull request con la lista de revisión final, Dependabot y `.editorconfig`.

Criterio de salida: CI obligatorio en `main`, staging funcionando, migraciones reproducibles desde cero, cobertura mínima acordada (propuesta: 60 % en servicios y reglas de negocio).

Fase 2 · Pagos en línea

Responsable: desarrollo + propietario · semanas 3 a 8

- **Decisión documentada (ADR):** proveedor, página de pago alojada por la pasarela (sin datos de tarjeta en nuestros sistemas), políticas de reembolso y de pedido sin pagar.
- **Modelo de datos:** tabla `payments` inmodificable (solo funciones del servidor escriben), estados del pedido ampliados («Pago pendiente», «Pagado», «Reembolsado»), llave de idempotencia por intento.
- **Servidor:** funciones de Supabase (Edge Functions) para crear el cobro y recibir el aviso de la pasarela con **verificación de firma**, tolerancia a avisos duplicados y reintentos limitados. El navegador jamás marca un pedido como pagado.
- **Cancelación y reembolso:** `cancel_order` pasa a iniciar el reembolso cuando el pedido está pagado; conciliación diaria entre pagos y pedidos con alerta si no cuadra.
- **Comisiones:** liquidación por pedido pagado y reporte para cada negocio; el cobro de los planes se deja para una segunda entrega.
- **Pruebas:** pago exitoso, rechazado, expirado, aviso duplicado, aviso falso (firma inválida), reembolso y cancelación, contra el entorno de pruebas de la pasarela y simulado en CI.

Criterio de salida: todos los casos anteriores pasan en automático; una compra real de bajo valor se paga, concilia y reembolsa en staging; ningún dato de tarjeta toca nuestro código ni nuestros registros.

Fase 3 · Operación y seguridad

Responsable: desarrollo · semanas 5 a 9

- **Observabilidad:** monitoreo de errores (con limpieza de datos personales), registros estructurados, aviso de caída (uptime) y alertas por pagos que no concilian o pedidos sin tomar.
- **Respaldo y recuperación:** activar copias automáticas, **probar una restauración** y medir el tiempo; procedimiento de reversa de despliegue (Vercel) y de migraciones. Sin esa prueba no se afirma que hay respaldo.
- **Seguridad:** encabezados (CSP y similares) en `vercel.json`; CAPTCHA y límite de intentos en registro y entrada; repetir la auditoría de esquema (`02_auditoria_esquema.sql`) y revisar las políticas RLS y de almacenamiento sobre el proyecto real; revisión tipo OWASP; política de rotación de claves.
- **Privacidad operativa:** atender solicitudes de datos desde un panel de administración con plazos (10 y 15 días hábiles), retención y borrado; pedir los consentimientos a las cuentas antiguas; **seguimiento del domiciliario solo durante una entrega activa** (hoy se envía la ubicación cada 30 s mientras está conectado) y con plazo de conservación.
- **Seguimiento en segundo plano:** una aplicación web no puede enviar ubicación con la pantalla apagada; decidir entre mantener la pantalla encendida (Wake Lock) con aviso claro, o empaquetarla como aplicación nativa más adelante.
- **Runbooks:** caída de Supabase, pagos que fallan, restauración, incidente de seguridad, rotación de claves y atención al cliente.

Criterio de salida: alertas probadas, restauración ensayada, auditoría RLS sin hallazgos críticos, encabezados activos, runbooks publicados en `docs/`.

Fase 4 · Prueba integral y piloto cerrado

Responsable: ambos · semanas 9 a 13

- **Recorrido de extremo a extremo automatizado** (cliente, negocio, domiciliario, administrador) contra staging con Supabase real, y repetido a mano en celulares reales (Android e iPhone).
- **Contenido real:** 5 negocios con catálogo y fotos, sitios turísticos y al menos 6 domiciliarios aprobados con declaración y fotografía.
- **Accesibilidad y rendimiento:** prueba de teclado y lector de pantalla en los flujos clave; medir carga en 4G (meta: la primera pantalla útil en menos de 2,5 s) y vigilar el tamaño del paquete.
- **Piloto:** 2 a 4 semanas con acompañamiento, primero en efectivo y luego con pagos reales de bajo monto; registrar pedidos, tiempos de entrega, cancelaciones, errores y llamadas de soporte.

Criterio de salida: lista Go/No-Go de la sección 5 cumplida y sin incidentes críticos abiertos en el piloto.

Fase 5 · Beta abierta y lanzamiento

Responsable: ambos · semanas 13 a 16

- **Apertura gradual** por cupos o por zonas, con horario de soporte definido y una persona responsable.
- **Lanzamiento comercial** cuando durante 2 semanas seguidas no haya incidentes críticos, los pagos concilien al 100 % y la tasa de errores sea baja; recién ahí promoción amplia.
- **Después del lanzamiento:** cobro automático de planes, migración de `react-router` a la versión 7, notificaciones push y, si el seguimiento lo exige, aplicación nativa.

3. Matriz de cumplimiento con la guía de calidad

Sección de la guía	Hoy	Evidencia o brecha	Acción	Fase
1–2 Principios y protocolo	PARCIAL	Cambios pequeños con pull request y fusión por «squash»; falta lista de revisión obligatoria.	Plantilla de pull request con la lista de la sección 18.	1
3–4 Nombres y comentarios	PARCIAL	Comentarios en español; mezcla de español e inglés en identificadores (`cancelarPedido`, `getStores`).	Documentar la convención; sin renombrado masivo; JSDoc en lo nuevo.	1
5 Arquitectura y estructura	PARCIAL	Servicios y vistas de 500 a 800 líneas con varias responsabilidades.	Dividir por dominio con pruebas de caracterización; capa `payments` aislada.	1–2
6 Consistencia y estilo	CUMPLE	ESLint sin errores en CI; sin formateador común.	`.editorconfig` y formato solo en archivos tocados.	1
7 Errores y resiliencia	PARCIAL	Avisos con «Reintentar» ya aplicados; cada servicio repite su manejo de errores; sin tiempos límite ni reintentos con espera.	Manejo de errores común, tiempos límite y reintentos solo en operaciones seguras.	1–2
8 Seguridad y privacidad	PARCIAL	RLS, funciones protegidas, totales y roles en el servidor, 0 alertas altas. Faltan encabezados, CAPTCHA, búsqueda de secretos, auditoría sobre el proyecto real y borrado de datos operativo.	Fase 3 completa.	3
9 Datos e integraciones	PARCIAL	38 parches sin registro de aplicados ni reversa; sin staging; sin tabla de pagos.	Migración base, CLI, reversas, tabla `payments` inmodificable.	1–2
10 Refactorización	PARCIAL	Limpieza reciente (dependencias, código muerto); quedan los archivos grandes.	Se resuelve con la división por dominio indicada en la sección 5.	1
11 Pruebas	PARCIAL	227 + 173 pasan; hay servicios sin pruebas, sin recorrido de extremo a extremo con Supabase real y sin umbral de cobertura.	Fases 1 y 4.	1,4
12 Dependencias	PARCIAL	Limpiadas y actualizadas; falta vigilancia automática y la migración mayor de `react-router`.	Dependabot y política de versiones mayores.	1,5
13 Rendimiento y observabilidad	FALTA	Sin monitoreo, registros estructurados ni medición de rendimiento.	Fase 3 y medición en Fase 4.	3–4

14 README y documentación	CUMPLE	README, estado del proyecto, normativa y guía de diagnóstico al día.	Agregar runbooks y el ADR de pagos.	2–3
15 Git y trazabilidad	PARCIAL	Ramas, commits descriptivos y pull requests; la rama `main` no está protegida.	Proteger `main` con CI obligatorio.	1
16 Configuración y despliegue	FALTA	Sin staging; despliegues en GitHub Pages y Vercel a la vez; respaldo y reversa sin comprobar.	Staging, un solo destino de despliegue, restauración ensayada.	1,3
17 Accesibilidad y experiencia	PARCIAL	Contraste sin hallazgos en ~50 pantallas, modo oscuro, estados de error; falta prueba de teclado y lector de pantalla.	Fase 4.	4
18–21 Revisión, formato y alcance	PARCIAL	Se verifica antes de entregar; falta volverlo regla del repositorio.	Lista en la plantilla de pull request; confirmación previa para operaciones sobre datos reales (runbooks).	1,3

4. Riesgos y decisiones que necesito de ti

Riesgos principales

- **Plazo legal:** la revisión del abogado y el régimen de domiciliarios pueden cambiar la declaración y el flujo de registro.
- **Pocos domiciliarios:** pedidos sin tomar dañan la reputación; hay que reclutar antes de abrir.
- **Pagos con repartidores independientes:** definir quién responde si el pedido llega mal o no llega.
- **Seguimiento en segundo plano** limitado en una aplicación web.
- **Dependencia de un solo proveedor** (Supabase): mitigada con respaldos probados.

Decisiones pendientes

- Pasarela: Bold o Wompi (comisión, tiempos de abono, reembolsos).
- Política de reembolsos y de cancelación con pedido pagado.
- Precios y comisiones definitivos de los planes.
- Horario y canal de soporte, y quién lo atiende.
- Dominio propio y un único destino de despliegue (Vercel o GitHub Pages).
- Persona o entidad responsable del tratamiento de datos.

5. Lista Go / No-Go para el lanzamiento comercial

Área	Se considera cumplido cuando…
Legal	Datos de la entidad cargados, textos revisados y firmados por abogado, registro ante la SIC resuelto según el caso y consulta de facturación hecha con el contador.
Seguridad	0 alertas altas en producción, auditoría de RLS sobre el proyecto real sin críticos, encabezados y CAPTCHA activos, búsqueda de secretos en CI sin hallazgos.
Pagos	Pruebas automáticas de pago, rechazo, aviso duplicado, firma inválida y reembolso en verde; conciliación diaria cuadrando al 100 % durante el piloto; sin datos de tarjeta en nuestros sistemas.
Calidad	CI obligatorio en `main`, cobertura mínima acordada, recorrido de extremo a extremo de los cuatro perfiles en verde en staging.
Operación	Restauración de respaldo ensayada con su tiempo medido, alertas probadas, runbooks publicados, soporte con horario y responsable.
Producto	Mínimo 5 negocios reales con catálogo y 6 domiciliarios aprobados; primera pantalla útil en menos de 2,5 s en 4G; prueba de teclado superada en los flujos clave.
Piloto	2 semanas seguidas sin incidentes críticos, cancelaciones y reembolsos funcionando, y las quejas de clientes atendidas dentro del plazo.

Este plan se mantiene como documento vivo: al cerrar cada fase se actualiza `docs/ESTADO_DEL_PROYECTO.md` con lo hecho y lo que sigue.